



Vulnerability Assessment Report

Cyber Security Internship Task 1

Prepared By:
Prashant Khare

Target Website:
<https://demo.testfire.net>

Cyber Security



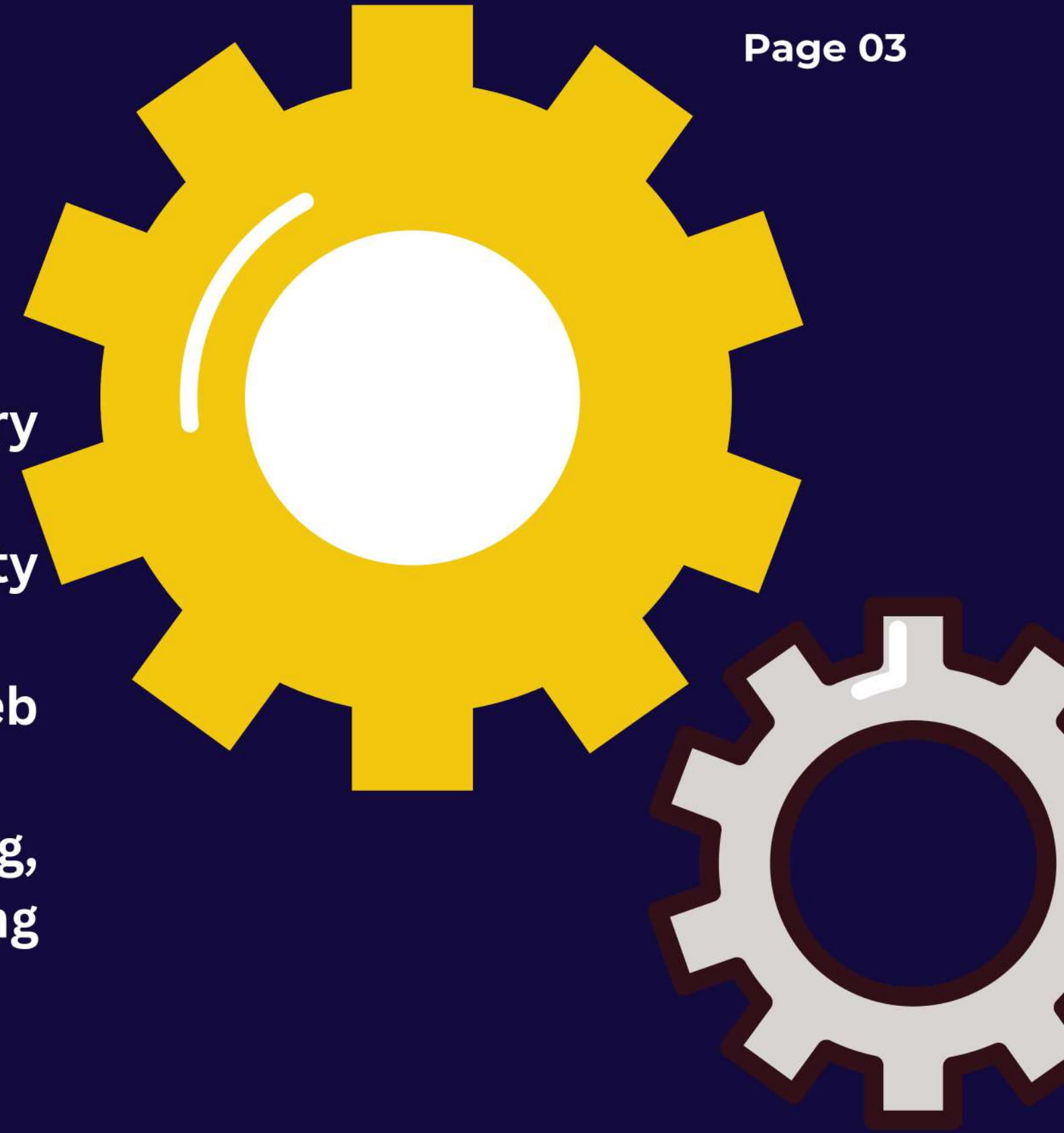
Objectives

- The objective of this task is to perform a passive vulnerability assessment on a public demo website using ethical and read-only testing techniques.
- To identify common web application security misconfigurations and missing HTTP security headers using passive reconnaissance and vulnerability assessment techniques.
- To gain practical experience with cybersecurity assessment tools such as OWASP ZAP and Nmap while following ethical and non-intrusive testing practices.



Tools :

- **GitHub** — Used for project documentation and repository management
- **Kali Linux** — Used as the testing environment for security assessment tools
- **Burp Suite Community Edition** — Used for passive web request and response analysis
- **OWASP ZAP** — Used for passive vulnerability scanning, HTTP header analysis, cookie inspection, and identifying common web security misconfigurations.



Findings

1. Content Security Policy (CSP) Header Not Set

Risk Level: Medium

The application does not implement a Content Security Policy header, increasing the risk of Cross-Site Scripting (XSS) attacks.

2. Missing Anti-clickjacking Header

Risk Level: Medium

The application does not protect against clickjacking attacks.

3. Cookie without SameSite Attribute

Risk Level: Low

Cookies are not configured with the SameSite attribute.

4. Server Version Information Disclosure

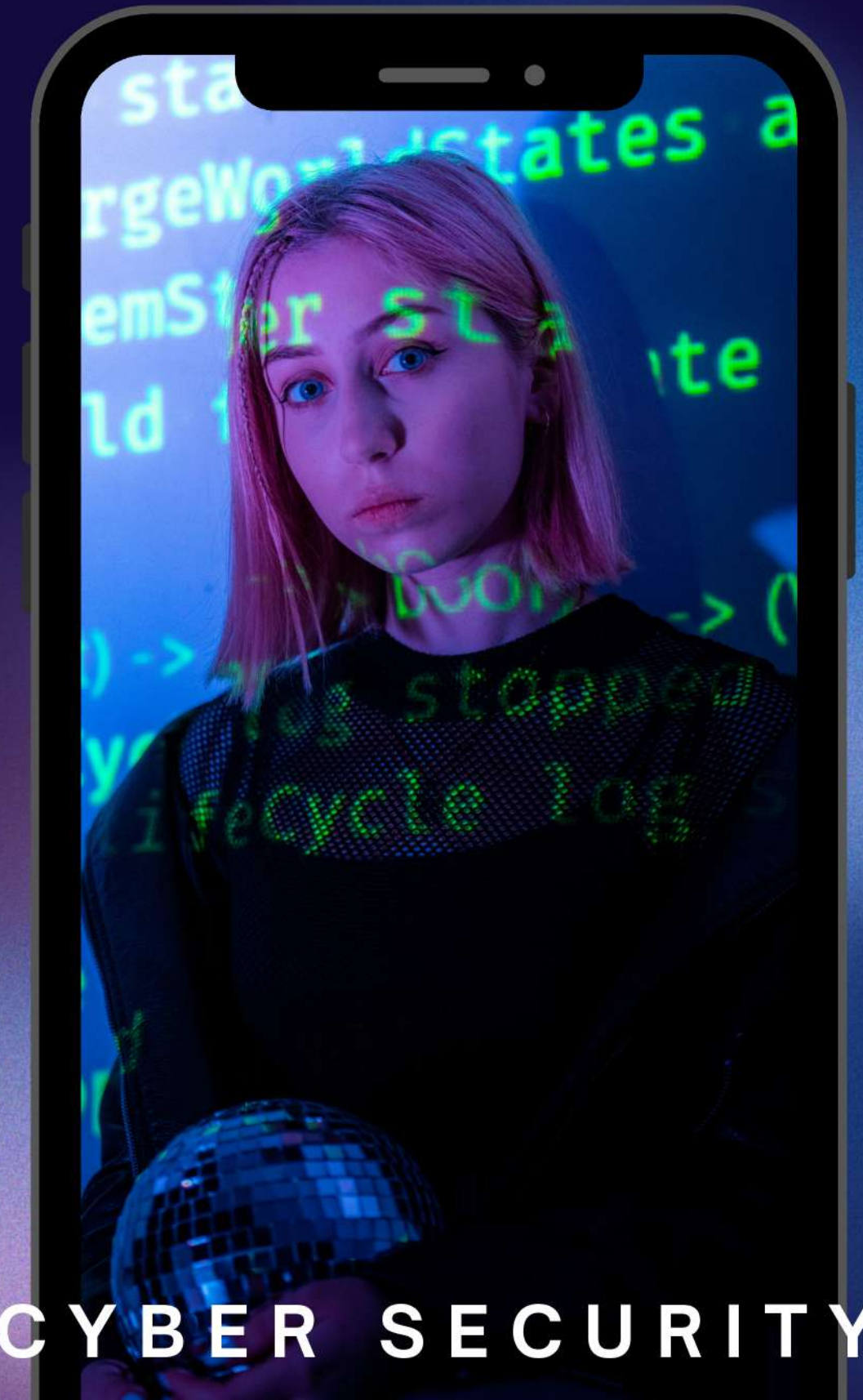
Risk Level: Low

The server exposes version-related information through HTTP headers.

5. Strict-Transport-Security Header Not Set

Risk Level: Medium

The application does not enforce secure HTTPS communication.





CSP Header Not Set

Risk: Medium

Description:

The application does not implement a Content Security Policy header.

Impact:

May increase XSS attack risk.

Recommendation:

Implement a strong CSP header.





Recommendations

- **Implement Content Security Policy headers**
- **Configure secure cookie attributes**
- **Hide unnecessary server information**
- **Enable HSTS protection**
- **Improve HTTP security headers**



CMD

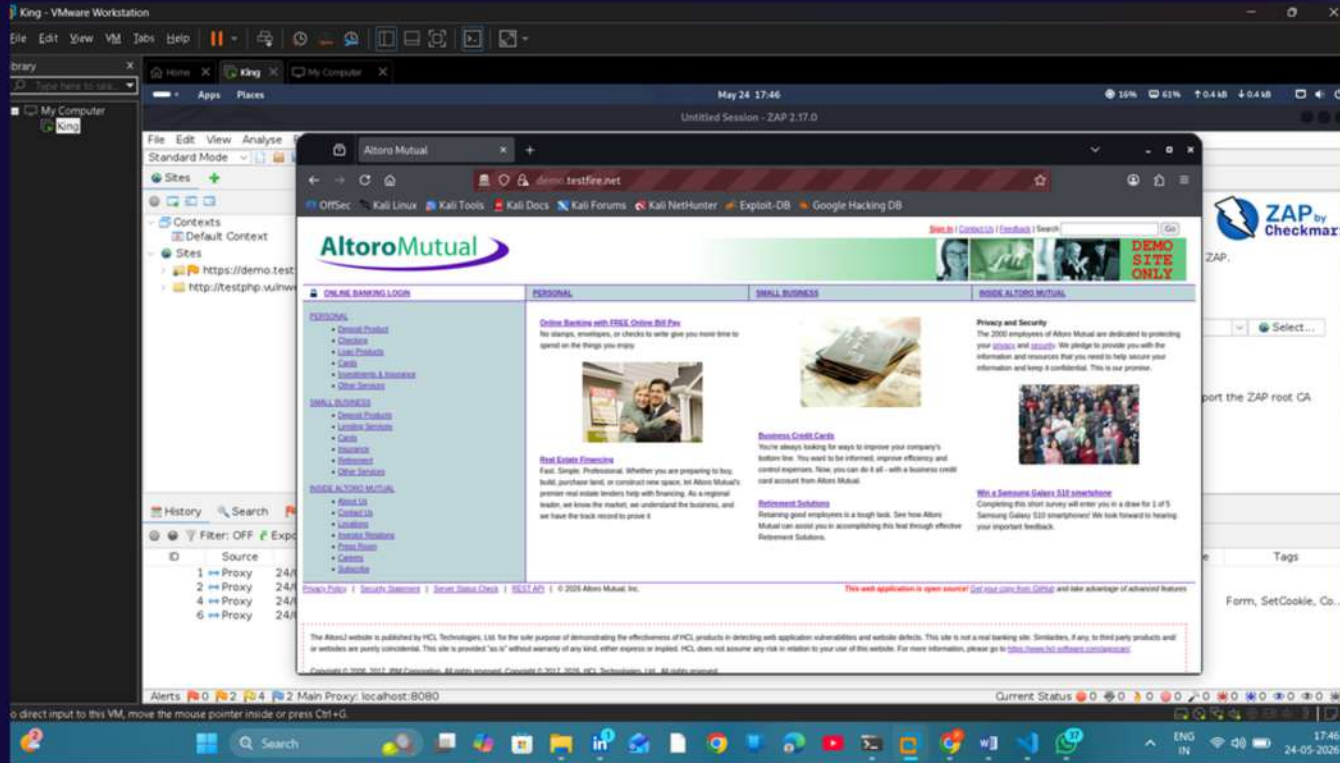
```
Microsoft Windows [Version 10.0.26200.8457]
(c) Microsoft Corporation. All rights reserved.

C:\Users\sarvadnya>nmap testphp.vulnweb.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-24 13:47 +0530
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.032s latency).
Other addresses for testphp.vulnweb.com (not scanned): 64:ff9b::2ce4:f903
rDNS record for 44.228.249.3: ec2-44-228-249-3-us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

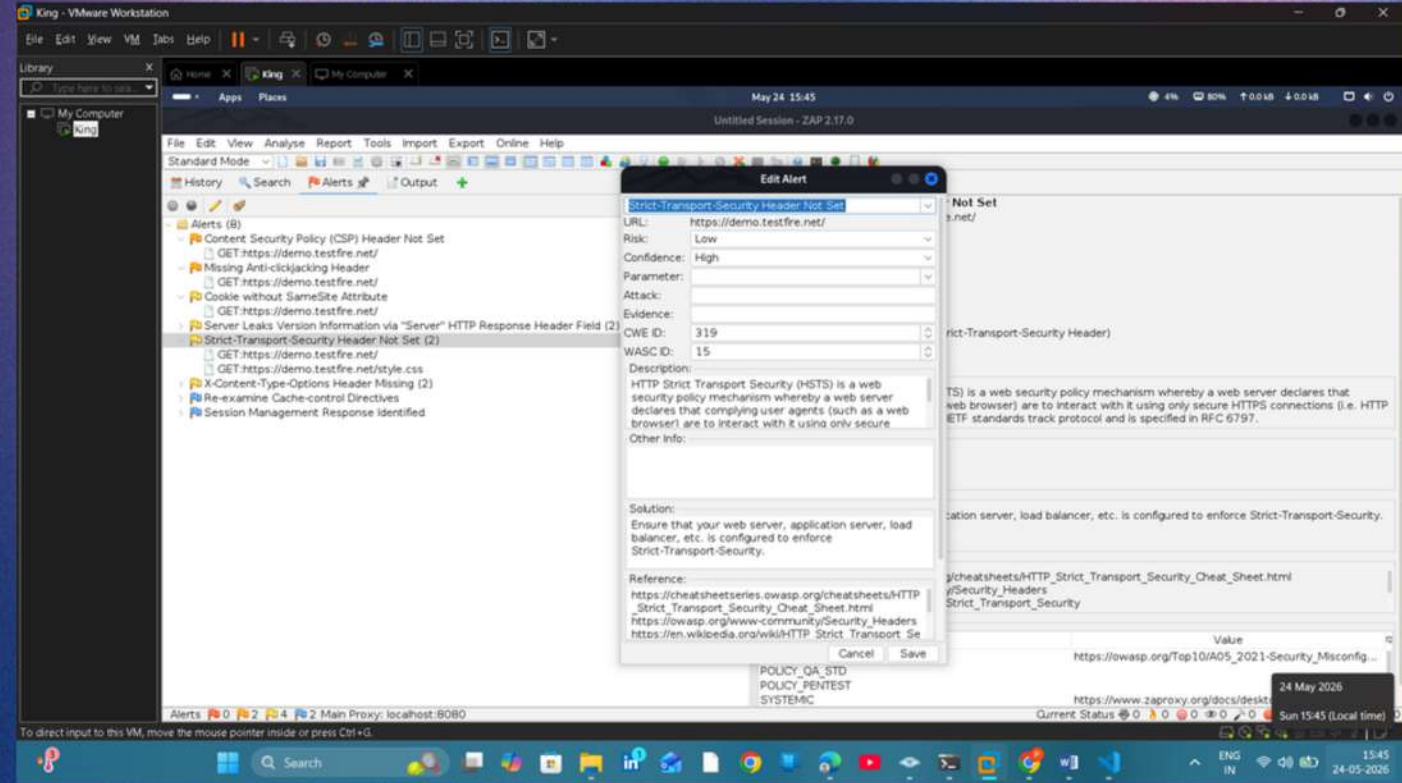
Nmap done: 1 IP address (1 host up) scanned in 7.97 seconds

C:\Users\sarvadnya>nmap testphp.vulnweb.com > result.txt
C:\Users\sarvadnya>
```

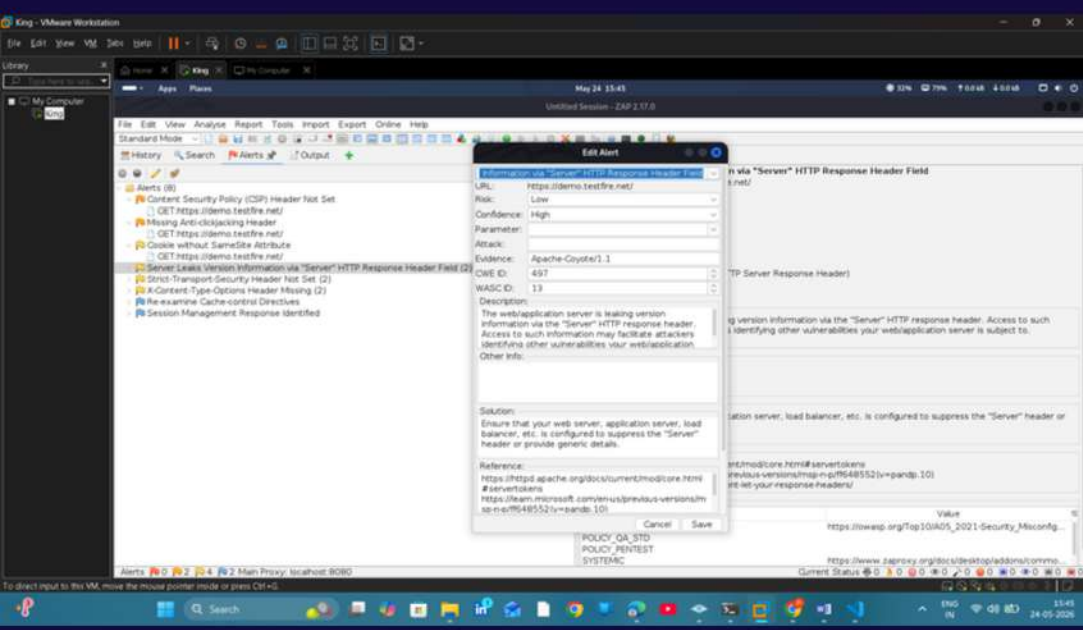
Web Application



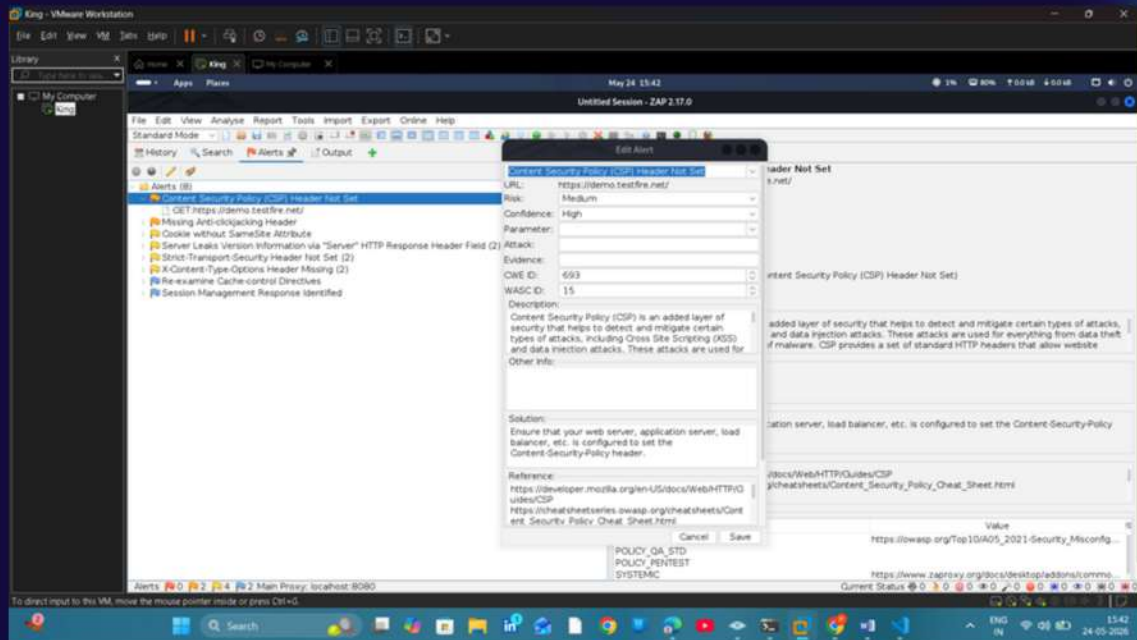
Server - Heder



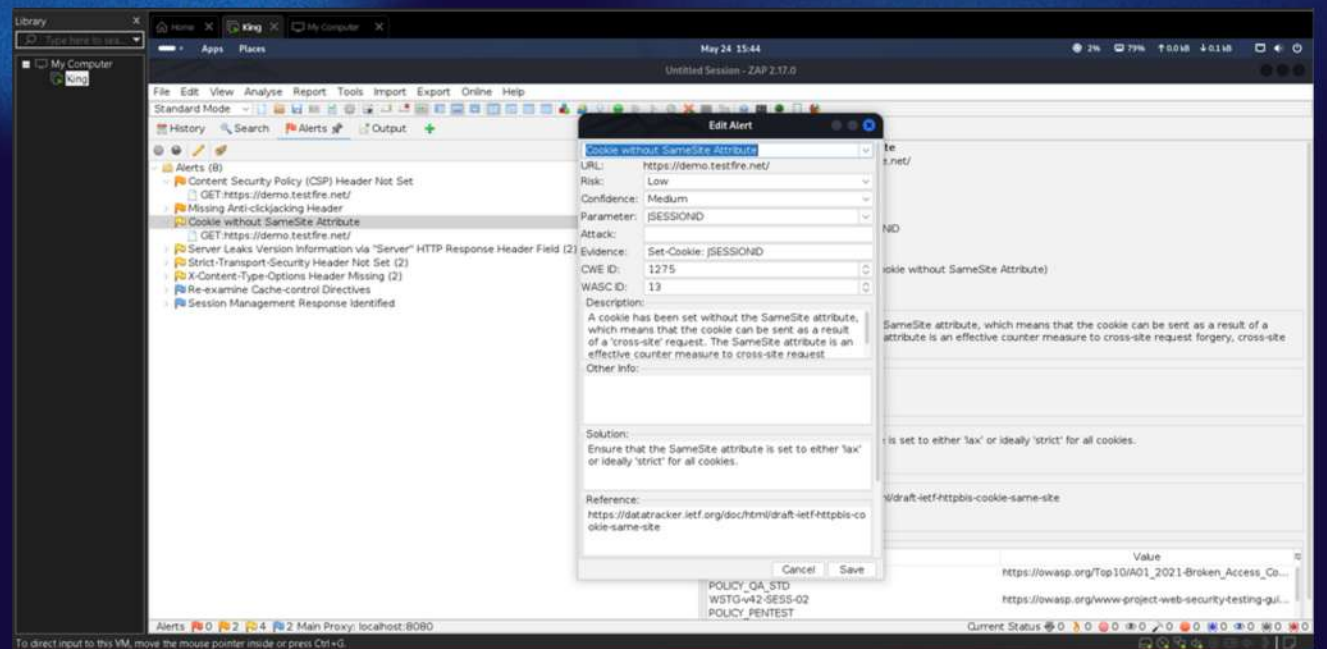
Information



Security



Cookie





Conclusion

The assessment identified multiple low and medium-risk security misconfigurations using passive and ethical testing techniques. The findings mainly relate to missing HTTP security headers, insecure cookie configurations, and minor information disclosure issues. Although no active exploitation was performed, these vulnerabilities may increase the application's exposure to common web-based attacks. Implementing the recommended security measures would help improve the overall security posture of the web application.